

Chapter One

Part - II

Fundamentals of Information security

Information Security
(SE7432)

Components of Information System Security

- ✎ The basic components of information security are Confidentiality, Integrity and Availability (C.I.A).
- ✎ These three components are the fundamental objectives of computer network and Information security.

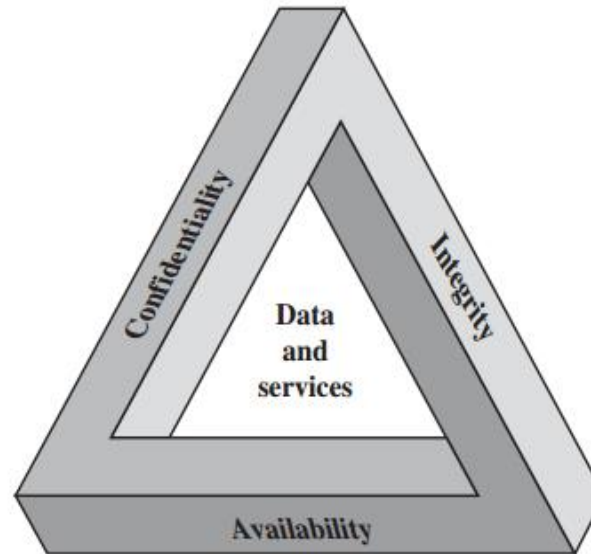


Figure 1: The Security Requirements Triad

Components of Information System Security (Cont....)

Confidentiality

-  Information has **confidentiality** when it is protected from disclosure or exposure to unauthorized individuals or systems.
-  Confidentiality ensures that *only* those with the rights and privileges to access information are able to do so.
-  When unauthorized individuals or systems can view information, confidentiality is breached.
-  To protect the confidentiality of information, you can use a number of measures, including the following:
 -  Information classification
 -  Secure document storage
 -  Application of general security policies
 -  Education of information custodians and end users

Components of Information System Security (Cont....)

Integrity

-  Information has **integrity** when it is whole, complete, and uncorrupted.
-  The integrity of information is threatened when the information is exposed to corruption, damage, destruction, or other disruption of its authentic state.
-  Corruption can occur while information is being stored or transmitted.
-  Information integrity is the cornerstone of information systems, because information is of no value or use if users cannot verify its integrity.
-  Key methods for assuring information integrity are:
 -  **file hashing**, in which a file is read by a special algorithm that uses the value of the bits in the file to compute a single large number called a **hash value**. The hash value for any combination of bits is unique. If a computer system performs the same hashing algorithm on a file and obtains a different number than the recorded hash value for that file, the file has been compromised and the integrity of the information is lost.
 -  look for changes in file integrity as shown by the size of the file

Components of Information System Security (Cont....)

Availability

-  enables authorized users—persons or computer systems—to access information without interference or obstruction and to receive it in the required format.
-  the assurance that the service will be available when it's needed
-  Assuring information and communications services will be ready for use when expected
-  Factors that affect the availability of Information and Information Security System (threats)
 -  Files stored in personal directories may not be available to other employees when needed
 -  Hardware failures could affect the availability of company resources
 -  A failure in the data circuit could prohibit system access
 -  Upgrades in the software may prohibit access

Principles of Information System Security

- ✧ Information Security principles denote the basic guidelines that should be used when designing a secure system
- ✧ There are many best practices in Information security that are specific to certain industries or businesses, but some apply broadly.
- ✧ **Balance Protection With Utility:** Deals in Information System Security the way of finding a balance between resource availability, the confidentiality and integrity of the resources. Rather than trying to protect against all kinds of threats, focus on insulating the most vital systems first and then finding acceptable ways to protect the rest without making them useless.
- ✧ **Split up the Users and Resources:** For an information Security system to work, it must know who is allowed to see and do particular things. This means that a system administrator needs to assign access by a person's job type, and may need to further refine those limits according to organizational separations.

Principles of Information System Security (Cont....)

- ✉ ***Assign Minimum Privileges:*** An individual should be assigned the minimum privileges needed to carry out his or her responsibilities. If a person's responsibilities change, so will the privileges. Assigning minimum privileges reduces the chances that Joe from design will walk out the door with all the marketing data.
- ✉ ***Use Independent Defenses:*** Using one really good defense, such as authentication protocols, is only good until someone breaches it. When several independent defenses are employed, an attacker must use several different strategies to get through them. Introducing this type of complexity doesn't provide 100% protection against attacks, but it does reduce the chances of a successful attack.
- ✉ ***Plan for Failure:*** This will help minimize its actual consequences should it occur. Having backup systems in place beforehand allows constantly monitor security measures and react quickly to a breach. If the breach is not serious, the business or organization can keep operating on backup while the problem is addressed.

Principles of Information System Security (Cont....)

 **Record, Record, Record:** Ideally, a security system will never be breached, but when a security breach does take place, the event should be recorded. In fact, IT staff often record as much as they can, even when a breach isn't happening. Sometimes the causes of breaches aren't apparent after the fact, so it's important to have data to track backwards. Data from breaches will eventually help to improve the system and prevent future attacks - even if it doesn't initially make sense.

 **Run Frequent Tests:** Hackers are constantly improving their craft, which means information security must evolve to keep up. IT professionals run tests, conduct risk assessments, reread the disaster recovery plan, check the business continuity plan in case of attack, and then do it all over again.

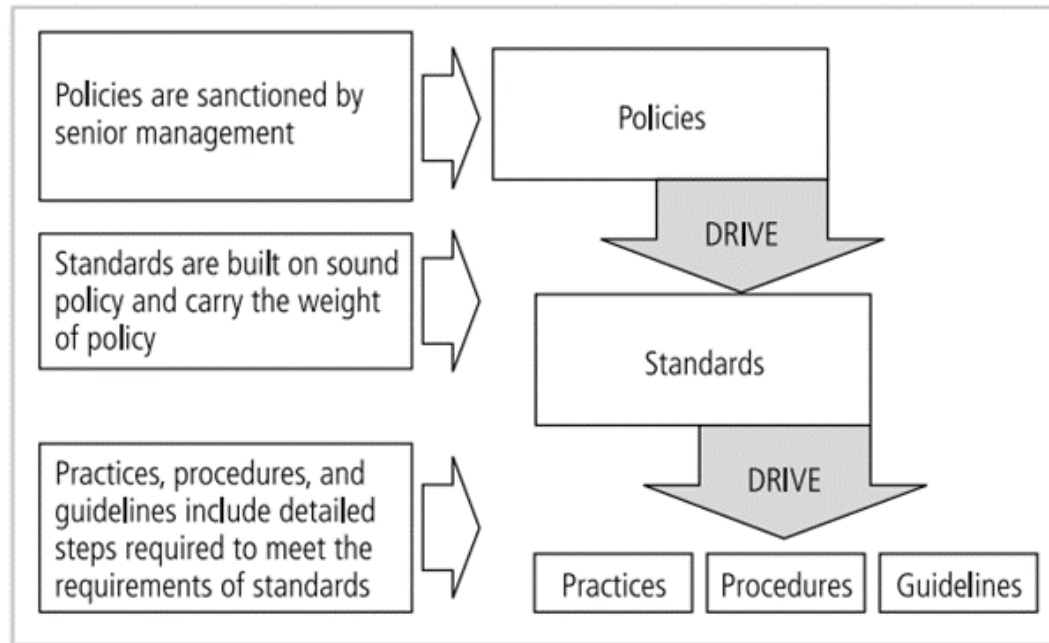
Introduction to Information Security Policy

- ✚ Is a document or set of documents that states an organization's intentions and decisions on what and how electronic information should be secured.
- ✚ a statement of what is and what is not allowed.
- ✚ It is a set of rules and practices that specify or regulate how a system or organization provides security services to protect sensitive and critical system resources.
- ✚ Is also the set of rules laid down by the security authority governing the use and provision of security services and facilities.
- ✚ Typically created by the CIO in conjunction with CEO and CISO, set the tone for all the subsequent security activities
- ✚ The meaning of security policy depends on the context of in which it is used.
 - ✚ Government agencies
 - ✚ Credit card agencies

Introduction to Information Security Policy (Cont....)

- ✚ The foundation for the information security architecture and blueprint: policy, standard and practices
- ✚ The creation and maintenance of these elements require coordinated planning. (strategic and contingency planning)
- ✚ Policies:- Like laws, they define what is right, what is wrong, what the penalties are for violating policy and what the appeal process is.
 - ✚ Put in place to support the mission, vision and strategic planning of an organization.
- ✚ Standards:- more detailed statements of what must be done to comply with policy.
 - ✚ Have the same requirements for compliance as policies
 - ✚ May be informal or part of an organizational culture
 - ✚ May be also published, scrutinized and ratified by group, as in formal
- ✚ Practices, Procedures and Guidelines:- effectively explain how to comply with policy.

Introduction to Information Security Policy (Cont....)



- ✎ Information security policy provide rules for the protection of the information assets of the organization
- ✎ Three types of security policies that must be defined by management (NIST SP-800-14)
 - ✎ Enterprise Information Security Policies
 - ✎ Issue-Specific Security Policies
 - ✎ Systems-Specific Security Policies

Introduction to Information Security Policy (Cont....)

✚ For a policy to be effective and thus legally enforceable, it must meet the following criteria:

✚ **Dissemination (distribution)**

- ✚ Demonstrate that the policy has been made readily available for review
- ✚ Common dissemination techniques include hard copy and electronic distribution

✚ **Review (reading)**

- ✚ Demonstrate that it disseminated the document in an intelligible form, including versions for illiterate, non-English reading, and reading-impaired employees.
- ✚ Common techniques include recording the policy in English and other languages

✚ **Comprehension (understanding)**

- ✚ Demonstrate that the employee understood the requirements and content of the policy
- ✚ Common techniques include quizzes and other assessments

Introduction to Information Security Policy (Cont....)

Compliance (agreement)

-  Demonstrate that the employee agrees to comply with the policy, through act or affirmation.
-  Common techniques include logon banners which require a specific action (mouse click or keystroke) to acknowledge agreement, or a signed document clearly indicating the employee has read, understood, and agreed to comply with the policy.

Uniform enforcement

-  Demonstrate that the policy has been uniformly enforced, regardless of employee status or assignment.

Plan, Design and implement Information Security

- ✚ Attacks against computers, in both home and business environments, have grown steadily
- ✚ Incidents of identity theft – the act of impersonating another person for profit or gain – are growing at an alarming rate
- ✚ Identity theft is considered one of the fastest growing crimes
- ✚ The need for information security should be apparent, but
 - ✚ The knowledge and ability to design and implement an effective security program requires
 - ✚ Substantial research, and
 - ✚ Often a great investment of time and resources.
 - ✚ To compound the problem, many home users lack the knowledge and experience to identify and understand their risk.
 - ✚ Moreover, while small businesses may understand, they either do not grasp the severity of the problem, or lack the resources to rectify it.

Plan, Design and implement Information Security (Cont.)

- ✧ Security software development life cycle includes the standard SDLC.
- ✧ Design may be based on:
 - ✧ Event Driven:
 - ✧ Started in response to some occurrence/security breach
 - ✧ Plan Driven:
 - ✧ Carefully developed in SDLC implementation strategy
- ✧ The general SDLC can be applied for security SDLC, but the phases has their own unique activities to be accomplished.
 - ✧ Requirement Analysis and Elicitation
 - ✧ System Design
 - ✧ Implementation
 - ✧ Testing
 - ✧ Maintenance

Plan, Design and implement Information Security (Cont.)

Requirement Analysis and Elicitation Phase

-  Establish the importance of information security in the business
-  Identify the basic security problems in the organization/business
-  Set the objectives of the security system you are going to design
-  Establish the security organization structure
-  Define the constraint and scope of the security system
-  Define security policy
-  Identify and Classify the Assets
-  Identify and Assess the Risks
-  Plan for Risk Management
-  Cost-benefit analysis and feasibility analysis
-  The current status of the organization is analyzed
-  How the new system will interact with the existing system (if any)

Plan, Design and implement Information Security (Cont.)

✧ Generally,

- ✧ Identify what you want to protect (the physical and the information asset)
- ✧ Perform risk assessment to determine what level of security is needed
- ✧ Prepare checklist to know your security strength
- ✧ Finally, security SRS Document will be delivered.

✧ System Design Phase

- ✧ Create a blueprint that will satisfy all documented requirements
- ✧ Identify all outputs, inputs, and processes
- ✧ The designer decided how the system will operate, in terms of:
 - ✧ The hardware, software, and network infrastructure;
 - ✧ The user interface, forms, and reports that will be used; and
 - ✧ The specific programs, databases, and files that will be needed

Plan, Design and implement Information Security (Cont.)

- ✚ Before starting the design, the following questions should be addressed by the first phase
 - ✚ Does the plan establish clear lines of command and indicate responsible officers?
 - ✚ Does the plan outline clearly when affected individuals should be notified of breaches?
 - ✚ Does the plan include a strategy to identify and address any weaknesses in data handling/data security that contributed to the breach?
- ✚ This turn to designing of controls and safeguards:
 - ✚ Managerial, Operational and Technical controls
- ✚ Managerial Control:
 - ✚ Addresses Risk Management Strategies and Security Control reviews
- ✚ Operational Controls:
 - ✚ Addresses disaster recovery and incident response planning, personal and physical security and protection of production input and outputs.
- ✚ Technical Control
 - ✚ Address those tactical and technical issues related to designing and implementing security in the organization and technologies necessary to protect information are examined and selected.

Plan, Design and implement Information Security (Cont.)

✎ Different types of designs will be designed

✎ High level design:

✎ Low level Design:

✎ Physical Design

✎ Logical Design

✎ Finally, SDD (Software Design document) will be delivered.

✎ **Implementation**

✎ In this phase, the new system is constructed

✎ The designed components and security solutions are acquired, arranged and implemented

✎ Personnel issues are evaluated and specific training and education programs conducted

✎ Coding and testing standards are applied and code reviews will be conducted

✎ Security testing tools, fuzzing tools, and Static analysis code scanning tools will be applied

Plan, Design and implement Information Security (Cont.)

Testing

 Different Testing will be applied at this phase.

 User Interface Testing

 Acceptance Testing

 Performance Testing

Maintenance

 Activities to support and modify the system will be identified

 Error/Fault Correction

 Adding new components

 Change adaptability

